ICOGemHunters

SMART CONTRACT SECURITY

THIRD-ROUND REVIEW

Smart Contract Audit Report

MoonsaleTokenVesting

BNB Smart Chain · Solidity ^0.8.20

REPORT ID	**IGH-MSL-2026-012**
CLIENT	**Moonsale App**
SCOPE	**MoonsaleTokenVesting.sol (third-round, I-01..I-04 + L-03/L-04)**
VERSION	**v3 (post-remediation of IGH-MSL-2026-011)**
METHODOLOGY	**Targeted diff review, regression scan**
ISSUE DATE	**April 23, 2026**

Executive Summary

This is a third-round targeted follow-up to `IGH-MSL-2026-011`. The client applied all four claimed Informational fixes (I-01 through I-04) cleanly and, additionally, silently resolved two Low severity findings that were not included in the change note but were in the previous report's recommended remediation order: L-03 (pagination) and L-04 (emergency pause). Six items fixed in total. No regressions introduced. No new findings. The score rises from **90 / 100** to **96 / 100**.

The `getVested` short-circuit on `s.revoked` (I-03) is notably clean: returning `s.claimed` freezes the view at the revoke moment and produces a coherent picture across all three vesting views (`getVested` frozen, `getClaimable` zero, `claim` reverts). The `OwnershipTransferred` event in `transferOwnership` is correctly emitted *before* the state write, capturing the old owner value in the event payload. These are the kinds of small details that reflect attentive remediation.

Overall Security Score	96 / 100	was 90 / 100

Verification

I-01 Fix — admin setter events

Two new events declared: `FeeRecipientUpdated(address indexed newRecipient)` and `OwnershipTransferred(address indexed oldOwner, address indexed newOwner)`. `setFeeRecipient` emits `FeeRecipientUpdated(_recipient)` after the state write. `transferOwnership` emits `OwnershipTransferred(owner, newOwner)` *before* the state write, which is the correct ordering: the event captures the outgoing owner's address before it is overwritten. All admin state changes are now reconstructable from event logs alone.

I-02 Fix — enriched ScheduleCreated event

New signature has nine positional arguments: `scheduleId` (indexed), `token` (indexed), `beneficiary` (indexed), `creator`, `totalAmount`, `tgePercent`, `cliffDays`, `vestingDays`, `startTime`. The emit call inside `createSchedule` passes all nine arguments positionally and matches the declaration. `creator` is correctly passed as `msg.sender`, and `totalAmount` is correctly passed as `received` (the post-M-02 balance-delta value). Indexers can now reconstruct the entire vesting curve from a single event.

I-03 Fix — getVested short-circuit on revoked

New first line in `getVested`: `if (s.revoked) return s.claimed;`. Because `revoke` sets `s.claimed = vestedSoFar` at the moment of revoke, the returned value is frozen at the revoke moment for all subsequent calls. The three views now agree for revoked schedules:

- `getVested(id)` returns `s.claimed` (frozen at revoke).
- `getClaimable(id)` returns `0` (short-circuit added in v2).
- `claim(id)` reverts with `"Schedule revoked"`.

I-04 Fix — removed unreachable branch

`getVested` previously contained `if (linearAmount == 0 || s.vestingDays == 0) return s.totalAmount;`. The `|| s.vestingDays == 0` disjunct was unreachable because `createSchedule` requires `vestingDays > 0 || tgePercent == 10000`, and `tgePercent == 10000` implies `linearAmount == 0`. The disjunct has been removed. Division safety verified: if `linearAmount == 0`, the function already returned `s.totalAmount`; if `linearAmount > 0`, `vestingDays > 0` and the later `linearAmount * elapsed / duration` computation is safe.

Unannounced Fixes

Two items from the previous report's remediation order were also resolved but not mentioned in the client's change note:

- **L-03 (pagination).** Three new paginated getters added: `getSchedulesByBeneficiaryPaginated`, `getSchedulesByTokenPaginated`, `getSchedulesByCreatorPaginated`. All use the `(offset, limit) -> (ids, total)` shape, matching the `MoonsaleTokenLock` convention. Bounds handling is correct (`offset >= total` returns empty; end clamped to `total`).
- **L-04 (emergency pause).** `bool public creationPaused` state, `setCreationPaused(bool)` `onlyOwner` setter emitting `CreationPausedUpdated`. `createSchedule` gates on `!creationPaused`. `claim`, `revoke`, and `sweepStuckETH` are correctly not gated, so paused state cannot strand existing participants.

Regression Scan

- `createSchedule` order and logic: unchanged. H-01 and M-02 fixes still in place.
- `claim`: byte-identical to v2.
- `revoke`: byte-identical to v2. C-01 fix preserved.
- `getVested` for non-revoked schedules: unchanged behaviour. The I-03 short-circuit only affects revoked schedules; the I-04 simplification is semantically equivalent given the `createSchedule` preconditions.
- Storage layout: `creationPaused` appended after `owner`. Storage-safe for fresh deploys (the contract is non-upgradeable).
- Event signature changes (I-01, I-02) are a breaking ABI change for any pre-existing indexer. This is expected and acceptable pre-mainnet.

Round-by-Round Status

ID	Finding (short)	Status
I-01	Events for setFeeRecipient and transferOwnership	RESOLVED
I-02	Enriched ScheduleCreated event	RESOLVED
I-03	getVested short-circuit on revoked	RESOLVED
I-04	Removed unreachable branch in getVested	RESOLVED
L-03	Paginated view functions	RESOLVED
L-04	Emergency pause on createSchedule	RESOLVED
L-01	No upper bound on cliffDays / vestingDays	ACCEPTED
L-02	Reverting feeRecipient DoSes createSchedule	DEFERRED
M-03	Single-step transferOwnership	ACCEPTED

Status legend. Resolved = fix verified in source. Accepted = client acknowledges the finding and has stated a compensating control or design rationale. Deferred = client has explicitly chosen to address later; treated as Accepted for scoring purposes.

Client Acceptance Notes

- **L-01 (no upper bound on cliffDays / vestingDays).** Client states that the platform UI enforces admin-configurable min/max bounds on the creation form, preventing out-of-range values through the normal user flow. Direct-contract callers are out of scope for this mitigation. This is a reasonable layered defence for a public-create contract where the UI is the primary entry point.
- **L-02 (reverting feeRecipient DoS).** Client defers this fix, same decision as applied to `MoonsaleTokenLock`. Operational responsibility for a non-reverting recipient rests with the owner. Mitigated in practice by keeping `feeRecipient` set to a standard multisig or EOA.
- **M-03 (single-step ownership).** Accepted tradeoff documented since `IGH-MSL-2026-005`. Client relies on multisig ownership as operational mitigation.

Summary

Clean, additive round. All four claimed Informational fixes apply correctly, and the client additionally resolved two Low findings that were on the previous report's remediation roadmap but not in this round's change note. No regressions in the existing security-critical paths. No new findings identified.

Three items remain open but are all client-accepted with stated rationale: L-01 is handled at the application layer, L-02 is deferred by the same design decision used for `MoonsaleTokenLock`, and M-03 is a documented tradeoff carried from the initial review. None are security-critical.

Deployment posture: production-ready. No blockers. The Moonsale vesting contract has now traversed a full audit arc from a 42 / 100 initial score with a Critical finding to a 96 / 100 third-round clean bill of health, with every security-critical issue resolved and every remaining item documented as accepted by the client.

Security Score	96 / 100	0 Critical · 0 High · 0 Medium · 0 Open Low · 0 Open Info

Disclaimer

This report reflects a point-in-time third-round follow-up review of the Solidity source code provided by the client on the issue date shown on the cover. It covers only the changes made since `IGH-MSL-2026-011`; items accepted or deferred by the client retain their original descriptions and recommendations. A successful audit does not guarantee the absence of vulnerabilities, and changes to the code after review invalidate the conclusions. This report is an advisory document and does not constitute financial, investment, legal, or tax advice. ICOGemHunters accepts no liability for losses arising from the non-implementation of recommendations contained herein, from implementation errors introduced when applying recommendations, or from interactions with contracts outside the reviewed scope.

MoonsaleTokenVesting has now completed three audit rounds. No further review is required for the items closed in this round. If any of the accepted items (L-01, L-02, M-03) are addressed in a future release, a short targeted follow-up can be requested.